

# Ara Proje Gösterimleri

CEN429 Güvenli Programlama — Hafta 7

Dr. Öğr. Üyesi Uğur CORUH · 30.10.2026

## Bu hafta: ara proje gösterimleri (RAP1)

---

- Ders anlatılmaz; her takım **ara raporunu teslim eder** ve **uygulamasını gösterir**
- RAP1 = vizenin **%60**'ı · Quiz-1 = **%40** →  $\text{Not\_Vize} = 0,6 \cdot \text{RAP1} + 0,4 \cdot \text{QUIZ1}$
- Ayrıntılı rubrik: proje rehberi · sıra, süre, teslim saati: ders sınıfı
- ⚠ Geç teslim kabul edilmez

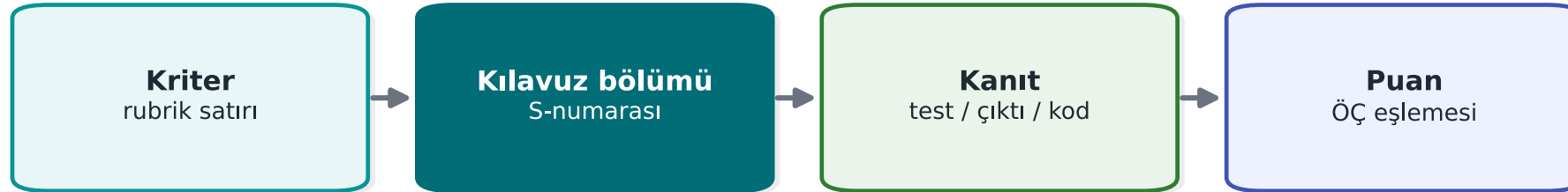
## Vize rubriği: beş kriter

| Kriter                       | ÖÇ | Kılavuzda                                           |
|------------------------------|----|-----------------------------------------------------|
| Güvenlik analizi             | 1  | S2 · S3 arayüz tablosu · S4 tehdit/saldırgan modeli |
| Veri güvenliği               | 2  | S5 varlık listesi · S7 kabuk matrisi                |
| C/C++ sağlamlaştırma ve RASP | 3  | S9 (temel) · S10                                    |
| Proje yönetimi               | 5  | S13 süreç, SBOM · GitHub deposu ve plan             |
| Ara rapor                    | 7  | Vize bölümlerinin tamamı                            |

# Rubriğin okunuşu — şema

## Rubrik nasıl okunur?

her puan satırı bir kanıta bağlanır



Kanıtı olmayan satır puanlanmaz — 13. haftanın uyum matrisi mantığı burada da geçerli.

## Ara raporda hangi bölümler?

| Tam                                                      | Taslak / kısa / plan                             |
|----------------------------------------------------------|--------------------------------------------------|
| S0 kapak · S2 genel bakış · S3 mimari · S4 tehdit modeli | S1 kapsam (taslak) · S5 varlıklar (taslak)       |
| S7 veri güvenliği · S10 RASP · S13 süreç                 | S9 sağlamlaştırma (temel) · S12 raporlama (kısa) |
|                                                          | S16 test (plan) · S17 uyum matrisi (taslak)      |

Finale kalanlar: S6 · S8 · S11 · S14 · S15

# RAP1 teslimi — şema

## RAP1 (vize) teslimi: ne bekleniyor?

ürünün ilk yarısı + kılavuzun ilk bölümleri

### S2 · Ürün ve mimari

bileşenler, arayüzler, güven sınırları

### S3 · Arayüzler

her arayüz için doğrulama

### S4 · Tehdit modeli

STRIDE + saldırı ağacı

### S5 · Varlık listesi

her varlık: konum, koruma şeması

### Temel korumalar

AEAD, güvenli silme, girdi doğrulama

$RAP1 = 0,7 \cdot \text{vize notu}$ . Kalan 0,3 Quiz-1'den gelir.

## Hazırlık kontrol listesi

| Hafta | Gösterebilmeniz gereken                                                      |
|-------|------------------------------------------------------------------------------|
| 1     | Depo + plan · S2 · S3 arayüz tablosu · S4 STRIDE + saldırı ağacı · S5 taslak |
| 2     | Her tehdit → CWE + CVSS v3.1 vektörü                                         |
| 3     | S7 algoritma/anahtar/bağlama · kabuk matrisi · CSPRNG · AEAD doğrulama       |
| 4     | S9 koruma tablosu · CERT bulguları · ASan+UBSan · fuzz sonucu                |
| 5     | SBOM + tarama · girdi doğrulama tablosu                                      |
| 6     | S10 RASP envanteri · tepki politikası · bir atlatma denemesi                 |

## Önerilen gösterim akışı

---

1. **Ürün ve mimari** (S2–S3): tek şema, güven sınırları
2. **Tehditler ve varlıklar** (S4–S5): en kritik üç tehdit
3. **Canlı gösterim**: en az bir önlem **çalışırken**
4. **Kanıt**: koruma tablosu, sanitizer/fuzz, SBOM — komut + çıktı
5. **Kalan risk ve plan**: finale kadar ne yapılacak?

Her önlem için: **Neyi korur? · Nasıl yapıldı? · Nasıl kanıtlandı?**

# Gösterim günü akışı — şema

## Gösterim günü akışı

toplam 20 dakika · takımın HER üyesi konuşur



Yazdığınız her satırı açıklayabilmelisiniz; açıklayamadığınız kod puan getirmez.

## Örnek sorular

---

- Güven sınırını geçen en riskli akış hangisi?
- Bu varlık bellekte ne kadar açık kalıyor, nerede siliniyor?
- Anahtar nereden geliyor, nerede duruyor? Nonce tekrar edebilir mi?
- Hangi derleyici koruması kapalı, neden?
- RASP denetimi başarısız olunca ne oluyor?
- SBOM'da zafiyetli bileşen var mı? Etkileniyor musunuz?

## Sık yapılan hatalar

| Hata                                      | Neden sorun?                                    |
|-------------------------------------------|-------------------------------------------------|
| Kılavuz ile kod tutarsız                  | En ciddi bulgulardan biri                       |
| Kanıtsız "güvenli" iddiası                | Puanlanmaz                                      |
| Varlık listesinde anahtar/günlük/kod yok  | Listede olmayan korunmuyor                      |
| Genel bilgiden tehdit tablosu             | Projeye özgü tehditler kaçır                    |
| Prova edilmemiş gösterim                  | Süre boşa gider                                 |
| Depoda gerçek parola/anahtar/kişisel veri | Ciddi güvenlik hatası; değerler <b>sentetik</b> |

# Sık yapılan hatalar — şema

## Gösterimde sık yapılan hatalar

değerlendirici kanıt arar, iddia değil

### YAPMAYIN

slaytta kod okumak  
'çalışıyor' deyip göstermemek  
tek kişinin konuşması  
kanıtsız 'güvenli' iddiası

### YAPIN

çalışan demoyu göstermek  
kararın GEREKÇESİNİ anlatmak  
ölçüm/kanıt sunmak  
sınırları dürüstçe söylemek

'Şunu yapamadık, nedeni şu' demek, olmayan bir şeyi var göstermekten iyidir.

# Akademik dürüstlük ve sonrası

---

- Kaynaksız kod/metin, takım dışı çalışma, uydurma sonuç **kabul edilmez**
- Teslim edilen her satır açıklanabilmeli
- Her takım üyesine soru sorulabilir

**Gösterimden sonra:** geri bildirimi **bulgu listesi** olarak yaz (bulgu · önem · düzeltme · tarih) → 12. haftanın küçük modeli

Final bölümleri: S6 · S8 · S11 · S14 · S15 · S16 sonuç · S17

# Gelecek hafta

---

## Hafta 8 — Ara sınav haftası: Quiz-1

- Kapsam: 1–6. haftalar
- Çalışma rehberi ve örnek sorular: 8. hafta sayfası

# Ek · Rubrik madde madde

# Rubrik neyi ölçer?

---

Vize gösterimi projenizin **ilk yarısını** ölçer:

- ürün, mimari, tehdit modeli
- varlık yönetimi
- temel korumalar
- belge ve sunum

## Madde · ürün ve mimari

---

- Ne yapıyor, hangi bileşenler?
- Tek şema + en kritik üç varlık.
- **Kanıt:** S2–S4 belgesi.

# Madde · tehdit modeli

---

- STRIDE / saldırı ağacı.
- Her tehdide bir önlem.
- **Kanıt:** S4 tehdit tablosu.

# Madde · varlık yönetimi

---

- Varlık listesi + C/I/I+.
- Yaşam döngüsü.
- **Kanıt:** S5.

## Madde · temel korumalar

---

- Kripto (S8, kısmi), güvenli kod (S9, kısmi).
- **Kanıt:** kod + test.

# Madde · belge ve sunum

---

- Tutarlılık, sürüm kimliği.
- Anlaşılır anlatım.
- **Kanıt:** kılavuzun tamamı.

# Ek · Gösterim akışı

## Akış · 1. özet

---

- Ürün, mimari, en kritik üç varlık.
- Tek şema, iki dakika.

## Akış · 2. tehdit modeli

---

- STRIDE ve saldırı ağacından bir örnek.
- "Bu tehdide şu önlem."

## Akış · 3. canlı gösterim

---

- Bir korumayı **çalışırken** göster.
- Ör. şifreli veri, doğrulanan imza.

## Akış · 4. kanıt

---

- Testler, koruma tablosu.
- "Şu komutla şu çıktı."

## Akış · 5. kalan risk

---

- Neyi bilerek kapsam dışı bıraktınız?
- Dürüst analiz puan getirir.

# Ek · Hazırlık kontrol listesi

## Kontrol · belge

---

- [ ] S0 sürüm kimliği güncel
- [ ] S2–S5 tam
- [ ] Kılavuz ile kod sürümü tutarlı

## Kontrol · gösterim

---

- [ ] Canlı demo çalışıyor (yedek video)
- [ ] Komutlar hazır
- [ ] Her takım üyesi bir bölümü anlatabiliyor

## Kontrol · güvenlik

---

- [ ] Depoda gerçek sır/kişisel veri yok
- [ ] Değerler sentetik
- [ ] Kalan risk yazılı

# Ek · Örnek sorular

# Soru 1

---

**En kritik üç varlığınız ve C/I/I+ etiketleri?**

Cevabı hazır tutun; her varlığın yaşam döngüsünü bilin.

## Soru 2

---

**Bu tehdide karşı hangi önlem, nasıl doğrulandı?**

Tehdit → önlem → kanıt zincirini gösterin.

## Soru 3

---

**Bu anahtar nereden geliyor, nerede duruyor, ne zaman siliniyor?**

Anahtar yaşam döngüsünü açıklayın.

## Soru 4

---

**Kalan riskiniz ne? Neden kabul edilebilir?**

Dürüst ve gerekçeli yanıtlayın.

# Ek · Sık yapılan hatalar

# Hata listesi

---

- Kılavuz ile kod sürümü farklı.
- Kanıtsız "yapıldı".
- Canlı demo çökmesi (yedek yok).
- Kalan risk bölümü boş.
- Depoda gerçek veri.

## Son söz (RAP1)

---

Gösterim bir **kanıt** sunumudur: her iddianın arkasında bir belge, test ya da canlı çıktı olsun.

Vize geri bildirimleri finalde **bulgu–aksiyon** listesine dönüşecek.